

Module8_CompensatingControls

Full technical solution

- 3 compensating controls with code examples
- Risk assessment (MEDIUM residual risk)
- Risk acceptance memo (template)
- Interim state (6 weeks) vs target state (end of FY)
- Exception prevention policy (6-point framework)

Board-ready summary

- Control overview (1 paragraph each)
- Risk rating justification
- Who accepts + when
- Timeline summary
- Talking points

Assessment compliance + governance

- Requirement-by-requirement mapping
- Risk acceptance template (ready to sign)
- Exception management deep-dive
- Board approval checklist

✅ Assessment Requirements (All Met)

Requirement	Coverage
3+ compensating controls	✅ App-layer encryption, Network isolation, Audit logging
From earlier modules (not invented)	✅ Module 5, 4, 6
Residual risk rating	✅ MEDIUM (60-70% reduction; acceptable interim)
Who accepts risk	✅ CISO + CIO (joint signature)

Requirement	Coverage
Time-bound plan	✅ Interim: 6 weeks; Target: End of FY (36 weeks)
Prevent exception sprawl	✅ 6-point exception management policy

The Three Compensating Controls

Control	From Module	How It Works	Risk Reduction
App-Layer Encryption	5	Proxy encrypts PII before tool sees it	Attacker gets ciphertext
Network Isolation	4	Database private; only proxy can connect	Can't reach DB from internet
Audit Logging & Detection	6	Every query logged + alerts	Breach detected in <60 seconds

Total deployment: ~40 hours

Risk Assessment

State	Likelihood	Impact	Rating	Acceptable?
Unmitigated	HIGH	CRITICAL	HIGH	❌ No
Mitigated	MEDIUM	HIGH	MEDIUM	✅ Yes (interim only)

Risk reduction: 60-70% (from HIGH to MEDIUM)

Timeline

Interim (NOW → 6 Weeks):

- Deploy 3 compensating controls
- ~40 hours engineering
- Board approval by Week 6

Target (7 Weeks → End of FY):

- Replace COTS tool with one supporting encryption
 - ~500 hours (RFI, POC, migration)
 - Tool live by end of FY; exception closed
-

 Exception Prevention Policy (6-Point)

1. **Exception Registry** — Central list (not spreadsheets)
2. **Strict Approval Gate** — CISO + CIO; 2-week review
3. **Rejection Criteria** — "It's expensive" ≠ approved
4. **Monthly Review** — Controls monitored; timeline tracked
5. **Board Visibility** — Quarterly dashboard (prevents creep)
6. **Process Friction** — Make it hard (on purpose)

Result: One exception does NOT become ten.

 Risk Acceptance Memo

Template provided (ready for CISO + CIO to sign):

- Controls described
 - Residual risk: MEDIUM (acceptable for 6 months)
 - Monthly monitoring scheduled
 - Exception expires end of FY (or tool replaced)
 - **This exception ≠ precedent for other systems**
-

Ready for Board Approval

Motion: "Approve MEDIUM residual risk for COTS financial tool

(with 3 compensating controls) for 6-month interim state.

Commit to replace tool by end of FY. Implement exception management policy to prevent other exceptions from this precedent."

Vote: ☒ APPROVED (if all three conditions met)

Success Criteria

- ☒ All 3 controls deployed by Week 6
- ☒ Risk acceptance memo signed
- ☒ Board approved (temporary exception)
- ☒ Monthly reviews scheduled
- ☒ Exception registry created
- ☒ Policy documented (prevent sprawl)
- ☒ Tool replacement tracking
- ☒ Compliance deadline met